

Risk assessment and treatment methodology

Classification: [internal/Public/confidential]

Use one of the following according to the needs with confirmation of required parties

version	Approved by	Owner	Date last updated	Review frequency	Next review	Comments

Table of Contents

Introduction.....	1
Purpose.....	1
Roles and responsibilities.....	1
Risk management approach	3
Risk Treatment.....	5

Introduction

This document offers a description of the approach employed by *[Company Name]* to do risk assessments and apply the applicable treatment plans under our ISMS. Conformant to ISO 27001, this displays the approach to be followed to identify security risks, assess these risks, conduct their treatment, and continually monitor them inside the organization.

The risk assessment provides information security management with the baseline to identify vulnerabilities and threats against information assets. The methodology of risk treatment defines the ways in which the identified risks will be mitigated, avoided, transferred, or accepted to effectively develop a security posture that will satisfy company goals.

Purpose

The purpose of this document is to establish a clear and consistent methodology for performing risk assessments and defining risk treatment actions. The document should provide a structured process for identifying, analyzing, and evaluating information security risks, outlines appropriate treatment measures, and aligns risk management with business strategy, legal obligations, and ISO 27001 compliance. The content is mainly for staff, auditors, suppliers and customers.

Roles and responsibilities

This section should define the key individuals and departments responsible for managing risks within the organization. Each risk owner is assigned specific duties to ensure effective identification, assessment, and treatment of risks. The risk owners have the authority and responsibility to implement necessary controls, monitor risk levels, and ensure compliance with the Information Security Management System (ISMS).

Example:

Roles	Risk owners	Responsibilities
-------	-------------	------------------

ISO27001 toolkit

IT Infrastructure	IT Infrastructure Manager, IT Security Manager	• Assure the safe configuration and upkeep of IT infrastructure. • Set things in place while keeping updated on network security measures.
Information Security	Chief Information Security Officer (CISO), Security Architect, IT Security Manager	• Create and manage security plans. • Monitor and minimize threats to security. • Verify adherence to ISO 27001 standards.
Operations Management	IT Operations Manager	• Continuous operation • Backup and disaster recovery controls
Development	Development Team Lead	• Adhere to secure processes for development. • Include security measures in software development processes.
Human Resources	HR Manager, IT Training Coordinator	• Employee security • Security training and awareness • Data protection for all the organization personnel

Risk management approach

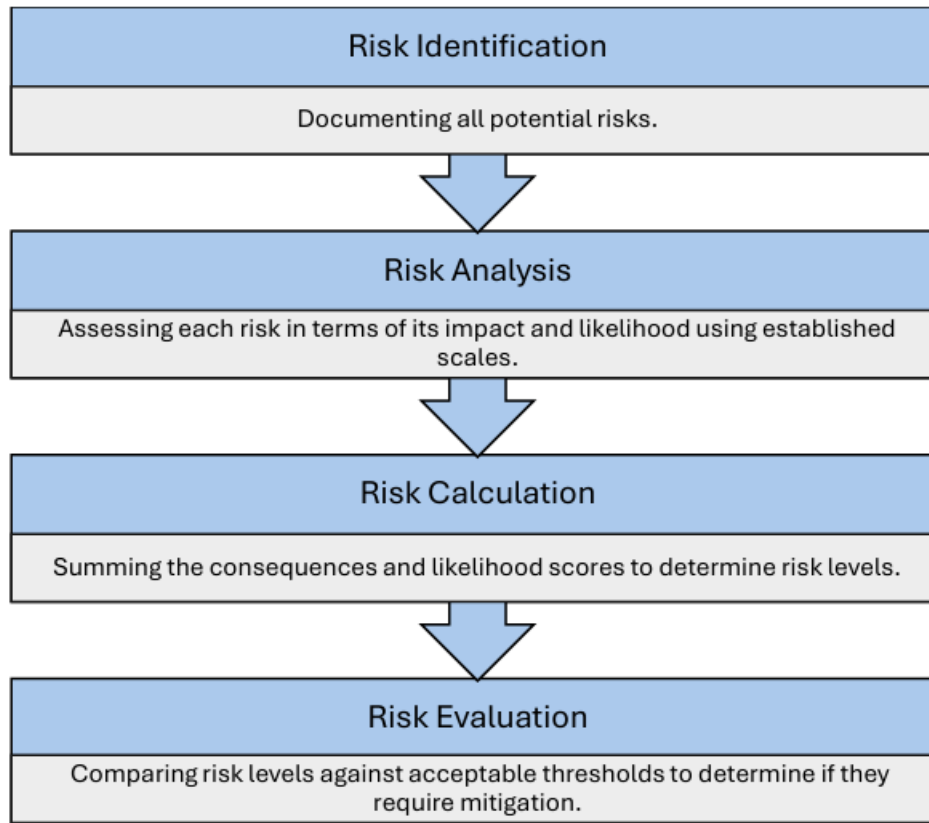


Figure 1 Risk Assessment Methodology

1. **Risk identification** – Risk identification involves identifying critical assets, potential threats, and vulnerabilities.

The first step in the risk management process is Risk Identification, where [Company Name] systematically identify potential risks to its information assets, processes, and systems.

Step	Description
Identify assets	Identify organizations critical assets that may be affected by different security threats Example: data, hardware, software, personnel
Recognizing Threats and Vulnerabilities	Identify different threats and vulnerabilities that could compromise the organization's critical assets Example: • Threats (cyber-attacks such as ransomware, phishing) • vulnerabilities (weak passwords, weak access controls, outdated software's)
Documentation	Record the identified risks of the organization.

2. **Risk Analysis** – analyzing the likelihood of each risk occurring

Organization can analyze the likelihood of each risk occurring using a simple scale of 0 to 4 like below. Likelihood means the probability of a risk occurring. Lower the probability lower the impact of the risk

- Consequences & likelihood (0-4)
 - 0 - Very Low: Minimal impact or likelihood.
 - 1 - Low: Minor disruption or damage.
 - 2 - Medium: Moderate impact or likelihood.
 - 3 - High: Significant impact or likelihood.
 - 4 - Very High: Severe impact or likelihood.

3. **Risk calculation** - Risk levels are then computed by adding the consequences and likelihood scores of the assessed threats and vulnerability values.

The [company name] should then calculate the risk by adding the consequences and likelihood scores of the threats.

- **Risk calculation formula= consequences +likelihood**

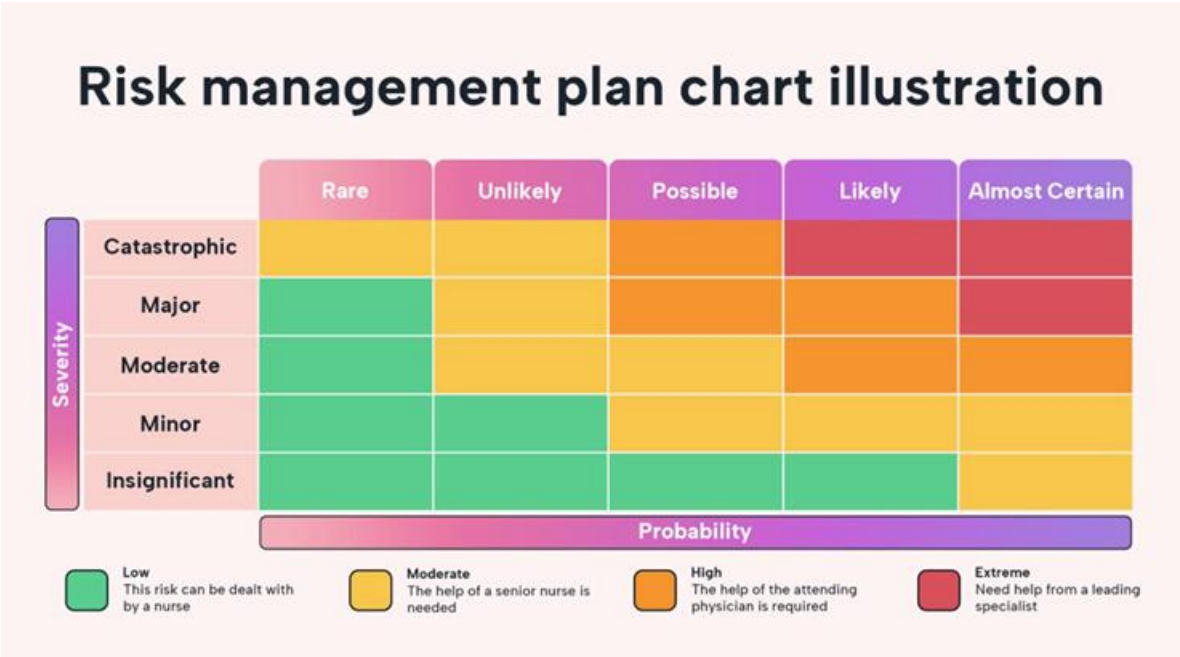
4. **Risk evaluation** - The computed risk levels are checked against acceptable thresholds to determine if they are controllable or require mitigation efforts to lower them to acceptable levels.

[Company Name] establishes an evaluation score by collaborating with relevant departments to assess each identified risk. For each risk, the **consequence** and **likelihood** are rated on a scale (0-4), and the two values are added together to calculate a total risk score. Based on [Company Name]'s predefined risk thresholds, the risk is either mitigated through appropriate treatment measures or accepted if the score falls within acceptable limits.

Here is a completed risk assessment table with all the required information

Asset	Threat	Vulnerability	Potential impact	Consequences	likelihood	Calculation	evaluation
Asset 1	Cyberattack (e.g., ransomware)	Insufficient encryption of data	confidentiality, integrity, availability	4	1	5	No
	System failure	Lack of regular backups	availability	3	3	6	Yes
	Unauthorized access	Inadequate access controls	confidentiality integrity	4	2	6	Yes
Asset 2	Data breach	Weak authentication mechanisms	confidentiality	4	3	7	Yes
	Server downtime	Absence of failover	availability	3	1	4	No

	Insider threat	Inadequate monitoring of user activities	confidentiality integrity	4	2	6	Yes
--	----------------	--	---------------------------	---	---	---	-----



Risk Treatment

The [company name] needs to develop plans to manage these risks. There are four main approaches when treating the risks.

- Avoid – avoid the risk by disrupting certain tasks or processes
- Mitigate - Reduce the risk by implementing controls and safeguards
- Transfer - Share the risk by moving it to a third party like an insurance company
- Accept - Accept the risk if the expense of minimizing it is more than the damage that would occur

This table outlines different **assets**, their associated **threats**, and the corresponding **risk treatment actions** taken by [Company Name] to manage these risks:

Asset	Threat	Action	Risk Treatment Action
Asset 1	Cyberattack (e.g., ransomware)	Risk Mitigation	Implement EDR, regular backups, and staff training
	System failure	Risk Avoidance	Use redundant infrastructure, cloud solutions, and regular hardware upgrades
	Unauthorized access	Risk Mitigation	Strengthen access controls and review permissions
Asset 2	Data breach	Risk Transfer	Obtain cyber insurance to transfer the financial risk associated with a data breach

ISO27001 toolkit

	Server downtime	Risk Mitigation	Implement failover solutions, conduct disaster recovery drills
	Insider threat	Risk Mitigation	Role-based access control, activity monitoring, and auditing